Universidad Nacional
Escuela de Informática

ADMINISTRACIÓN DE BASES DE DATOS

Controles ISO/IEC 27001:2022 para la confidencialidad en la administración de bases de datos

Auditoría sobre Oracle Database 21c Express Edition

ESTUDIANTE
Emmanuel Rodriguez Picado

PROFESOR
Johnny Villalobos Murillo

PERIODO
II Ciclo 2026

FECHA DE ENTREGA
27 de octubre de 2026

ALCANCE

Qué contiene este informe

Este informe reúne el marco teórico, las evidencias y las referencias. La tabla de uso de inteligencia artificial y la declaración jurada se entregan en un documento aparte. Las tablas de riesgos, tareas del DBA, mapeo de controles ISO, controles observables, matriz de evaluación y batería de pruebas están en el artefacto interactivo: enlace al artefacto. Los scripts `01_verificacion_confidencialidad.sql` y `02_actuar_correcciones.sql` están en el repositorio.

CICLO PHVA

Qué se hizo y qué se encontró

Resultado de aplicar el ciclo PHVA a la confidencialidad de la base de datos.

P

Planificar

7 riesgos de confidencialidad y 15 tareas del DBA, enlazados a controles del Anexo A (ver artefacto).

H

Hacer

Script `01_verificacion_confidencialidad.sql`: 17 consultas de solo lectura sobre XEPDB1.

V

Verificar

Matriz de evaluación con criterio 0 a 4 y evidencia por fila (ver artefacto).

A

Actuar

Script `02_actuar_correcciones.sql`: 4 correcciones, 3 aplicadas y 1 rechazada por permisos.



Cinco hallazgos que más pesan

- TDE está disponible en XE pero sin configurar: el wallet figura `NOT_AVAILABLE`.

- La base trabaja en `NOARCHIVELOG`, lo que limita los respaldos en caliente.
- Cualquier usuario puede ejecutar `UTL_FILE`, `UTL_HTTP`, `UTL_TCP`, `UTL_SMTP` y `DBMS_DATAPUMP`.
- El perfil `DEFAULT` no exige complejidad de contraseña y mantiene verificadores 11G.
- No existen políticas propias de Data Redaction ni de VPD.

FUNDAMENTO

Marco teórico

1. Cambios de ISO/IEC 27001:2022 respecto a 2013

La tercera edición de ISO/IEC 27001 se publicó el 25 de octubre de 2022 y especifica los requisitos para establecer, implementar, mantener y mejorar continuamente un sistema de gestión de seguridad de la información (International Organization for Standardization [ISO] & International Electrotechnical Commission [IEC], 2022). La norma aclara que omitir cualquier requisito de las cláusulas 4 a 10 no es aceptable cuando se declara conformidad; lo que cambió de forma más visible es el Anexo A, alineado con ISO/IEC 27002:2022.

En la edición de 2013 el Anexo A tenía 114 controles organizados en 14 temas y 35 categorías. La edición de 2022 lo reduce a 93 controles agrupados en cuatro temas: organizacionales, de personas, físicos y tecnológicos. Once controles son nuevos: inteligencia de amenazas, seguridad de la información en el uso de servicios en la nube, preparación de las TIC para la continuidad del negocio, monitoreo de la seguridad física, gestión de la configuración, eliminación de información, enmascaramiento de datos, prevención de fuga de datos, actividades de monitoreo, filtrado web y codificación segura. Además, 24 controles de la versión anterior se fusionaron, y cada control incorpora cinco atributos cuyo uso es opcional y que la organización puede ignorar o sustituir por otros, como un modelo de madurez (SGS, 2022).

Para un administrador de bases de datos (DBA), el cambio es relevante porque la confidencialidad ya no depende únicamente de controles de acceso. El enmascaramiento de datos (A8.11), la prevención de fuga de datos (A8.12) y las actividades de monitoreo (A8.16) son ahora controles explícitos y, por tanto, auditables. Este trabajo aplica el ciclo PHVA (Planificar, Hacer, Verificar, Actuar) a un subconjunto de controles del Anexo A y los evalúa con evidencia tomada de Oracle Database 21c Express Edition.

2. Principio de mínimo privilegio y separación de funciones en el rol DBA

El principio de mínimo privilegio establece que cada identidad reciba únicamente los permisos que necesita para su función. La separación de funciones complementa esa idea: evita que una sola persona concentre tareas incompatibles, por ejemplo administrar a los usuarios y, a la vez, administrar o borrar los registros de auditoría que vigilan esa administración. En el Anexo A estos principios se expresan en la separación de funciones (A5.3), el control de acceso (A5.15), los derechos de acceso (A5.18) y los derechos de acceso privilegiado (A8.2).

El rol de DBA es el caso extremo del problema, porque en Oracle una cuenta con el rol DBA o con el privilegio SYSDBA puede leer cualquier dato. Por eso el control práctico consiste en reducir esas cuentas al mínimo y que sean nominales (no compartidas), evitar los privilegios ANY y las delegaciones con ADMIN OPTION que no estén justificadas, y revisar periódicamente las vistas DBA_ROLE_PRIVS, DBA_SYS_PRIVS, DBA_TAB_PRIVS y V$PWFILE_USERS. En este trabajo, esa revisión mostró que solo SYS y SYSTEM tienen el rol DBA, que solo SYS figura en el archivo de contraseñas y que los roles AUDIT_ADMIN y AUDIT_VIEWER están asignados únicamente a SYS, lo que separa la administración de los datos de la administración de los registros. La arquitectura de confianza cero adopta el mismo criterio: el acceso a cada recurso se concede por sesión y con los privilegios mínimos necesarios, y acceder a un recurso no otorga acceso a otro (Rose et al., 2020).

3. Defensa en profundidad y Zero Trust aplicado a bases de datos

La defensa en profundidad superpone capas de control independientes para que la falla de una no exponga los datos. Aplicada a una base de datos, y como síntesis propia de este trabajo, las capas son cuatro: la red (tráfico cifrado y listener restringido), la identidad (autenticación, perfiles de contraseña y

mínimo privilegio), los datos (cifrado en reposo, redacción y filtrado por fila) y la supervisión (auditoría y alertas). Ninguna capa sustituye a otra: un perfil de contraseñas robusto no protege un respaldo robado, y el cifrado del disco no impide que un usuario con demasiados privilegios consulte datos sensibles.

Zero Trust (confianza cero) parte de otro supuesto: la red ya puede estar comprometida. Rose et al. (2020) lo definen como un conjunto de conceptos para aplicar mínimo privilegio y decisiones de acceso por solicitud. Entre sus principios, todas las fuentes de datos y servicios de cómputo se tratan como recursos; la comunicación se protege sin importar la ubicación de red; las decisiones de acceso se basan en una política dinámica que considera la identidad, el estado del dispositivo y el comportamiento; la autenticación y la autorización se aplican antes de conceder el acceso y se reevalúan durante la sesión; y la organización monitorea de forma continua la postura de seguridad de sus activos, sin confiar en ninguno por defecto (Rose et al., 2020). Aplicado a la base de datos, significa que ninguna conexión es confiable por venir de la red interna: cada una debe autenticarse, cifrarse, limitarse a lo necesario y quedar registrada.

4. Controles técnicos: TDE, Dynamic Data Masking, Data Redaction, Row Level Security / VPD y TLS

Transparent Data Encryption (TDE). Cifra los datos en reposo de forma transparente para usuarios y aplicaciones: los cifra al escribirlos en disco y los descifra al acceder a ellos, con administración de claves integrada. Protege frente a ataques que evitan la base de datos y leen los archivos directamente, como ransomware, respaldos perdidos o robados y lectura con herramientas del sistema operativo. Se puede cifrar columnas o tablespaces completos, y Oracle indica que, en casi todos los casos, el cifrado de tablespace debe ser la primera opción (Oracle, s. f.-d). En el entorno evaluado TDE está disponible, pero el wallet figura en NOT_AVAILABLE, es decir, no hay cifrado en reposo configurado.

Dynamic Data Masking y Data Redaction. El enmascaramiento dinámico oculta el valor real al momento de la consulta sin modificar lo almacenado. En Oracle esta función corresponde a Data Redaction, que enmascara dinámicamente los datos a medida que se seleccionan: no altera los datos almacenados, sino su presentación, de modo que las sesiones sin permiso ven valores enmascarados y las autorizadas ven los reales. La redacción se aplica antes de que la consulta devuelva los datos y Oracle la señala como apoyo para normativas como PCI DSS y Sarbanes-Oxley (Oracle, s. f.-d). Se relaciona con el control A8.11 (enmascaramiento de datos). En el entorno evaluado no hay políticas de redacción definidas.

Row Level Security y Virtual Private Database (VPD). La seguridad por fila restringe qué filas puede ver cada usuario. En Oracle se implementa con VPD, que añade una cláusula WHERE dinámica a las sentencias SQL del usuario. La política se asocia a una tabla o vista con el paquete DBMS_RLS y se aplica sin modificar la aplicación; una función PL/SQL devuelve el predicado, que puede depender de datos de la sesión, como el usuario conectado. Al residir la regla en la base de datos y no en el código de la aplicación, hay un único lugar de mantenimiento y menos vías alternas de acceso (Oracle, s. f.-f). En el entorno evaluado las 12 políticas existentes son internas del esquema XDB; no hay políticas propias.

TLS en las conexiones. El protocolo TLS cifra la comunicación entre cliente y servidor y puede autenticar solo al servidor o a ambos extremos mediante certificados; el algoritmo de cada suite de cifrado determina también la protección de integridad. En Oracle se usa el protocolo TCPS en el listener y las claves y certificados se guardan en un wallet, para el cual Oracle recomienda las herramientas orapki y mkstore (Oracle, s. f.-b). En el entorno evaluado el listener atiende las conexiones SQL por TCP en claro en el puerto 1521, y el único punto con TLS (puerto 5500, con wallet) corresponde al acceso web de XDB; sqlnet.ora no define parámetros de cifrado. Esto se evalúa con el control A8.20.

5. Data Leakage Prevention (DLP) y gestión de backups cifrados

La prevención de fuga de datos (A8.12) es uno de los controles nuevos de 2022 (SGS, 2022). En un motor de bases de datos no se resuelve con una sola herramienta: se concreta combinando los controles anteriores (privilegios mínimos, redacción y cifrado) con la restricción de las vías de salida de la información. Las más comunes son los paquetes PL/SQL que envían datos fuera de la base o los escriben en archivos (UTL_HTTP, UTL_TCP, UTL_SMTP, UTL_FILE y DBMS_DATAPUMP), los directorios de exportación y los respaldos. En el entorno evaluado esos cinco paquetes son ejecutables por PUBLIC, y el intento de revocarlos falló por no ejecutarse con el usuario que los otorgó (SYS).

Los respaldos son una vía clásica de fuga: Oracle menciona los respaldos perdidos o robados como una amenaza que TDE ayuda a mitigar (Oracle, s. f.-d). En RMAN, el cifrado de modo dual combina contraseña y TDE (si TDE está configurado, se omite la palabra ONLY en SET ENCRYPTION), y la documentación advierte que, si se pierde la contraseña, el respaldo no puede restaurarse (Oracle, s. f.-a). Por eso la gestión de claves y la custodia de contraseñas son parte del control de respaldos (A8.13). En el entorno evaluado la base opera en NOARCHIVELOG y no hay trabajos de respaldo RMAN visibles desde el PDB, lo que limita tanto la recuperación como el cifrado de copias.

6. Logging, monitoreo y correlación (SIEM)

La guía NIST SP 800-92 recomienda mantener una infraestructura de gestión de registros en tres niveles (generación, análisis y almacenamiento, y monitoreo) y definir políticas que indiquen qué eventos son de registro obligatorio. También recomienda sincronizar los relojes de los equipos, normalizar los formatos porque las fuentes producen contenidos inconsistentes, y analizar los registros de forma proactiva y, cuando sea posible, casi en tiempo real. Señala que herramientas como el software SIEM ayudan a correlacionar entradas de múltiples fuentes. En cuanto al almacenamiento, los registros deben rotarse y archivarse por los plazos que exijan las normas, protegerse en su confidencialidad e integridad (por ejemplo, con resúmenes criptográficos) y conservarse los originales sin alteración (Kent & Souppaya, 2006).

En Oracle, la base registra con la auditoría tradicional (parámetro audit_trail) y con la auditoría unificada, cuyas políticas generan la evidencia que un SIEM consumiría, accesible en la vista UNIFIED_AUDIT_TRAIL. En Oracle 21c XE la auditoría unificada en modo puro no está disponible y opera en modo mixto, limitación que se documenta en este trabajo. Estos controles corresponden al registro de eventos (A8.15), las actividades de monitoreo (A8.16) y la protección de los registros (A5.33). En el entorno evaluado se creó una política propia sobre la administración de usuarios y se comprobó que registra los eventos con su código de retorno.

7. Normativa costarricense: Ley 8968 y su reglamento

La Ley n.º 8968, firmada el 7 de julio de 2011, protege a la persona frente al tratamiento de sus datos personales. Reconoce la autodeterminación informativa como derecho fundamental (art. 4), exige consentimiento informado, expreso y revocable (art. 5) y obliga al responsable de la base de datos a adoptar medidas técnicas y organizativas que protejan los datos frente a alteración, destrucción, pérdida o acceso no autorizado, incluyendo como mínimo mecanismos de seguridad física y lógica acordes con la tecnología actual (art. 10). El artículo 11 impone el deber de confidencialidad a quien intervenga en cualquier fase del tratamiento, incluso después de terminada la relación, y solo un juez puede relevarlo de ese deber en lo estrictamente necesario (Asamblea Legislativa de la República de Costa Rica, 2011). La Agencia de Protección de Datos de los Habitantes (PRODHAB), adscrita al Ministerio de Justicia y Paz, vela por su cumplimiento y lleva el registro de bases de datos (arts. 15 y 16).

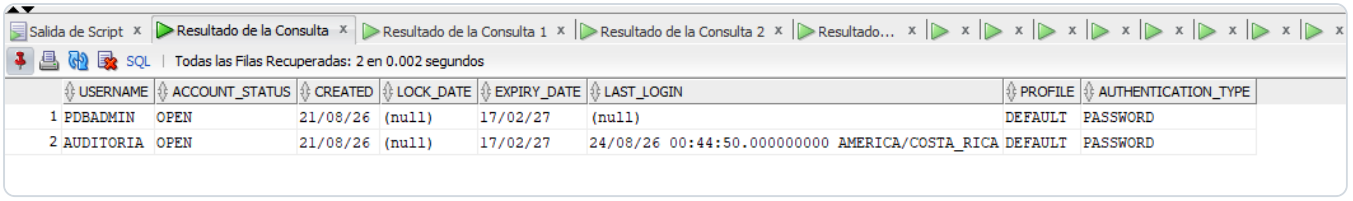
El Reglamento (Decreto Ejecutivo n.º 37554-JP) concreta esas obligaciones. Exige protocolos mínimos de actuación que incluyan medidas técnicas para mantener un historial de los datos personales (art. 32) y salvaguardas administrativas, físicas y lógicas (art. 34). Dispone que las medidas se definan según la

sensibilidad de los datos, el desarrollo tecnológico, las consecuencias de una vulneración y el número de titulares (art. 35), y que el responsable realice un análisis de riesgos con cálculo del riesgo residual y un plan de trabajo para las medidas faltantes (art. 36). Las medidas deben actualizarse cuando cambian los procesos, los riesgos o la plataforma y, si hay datos sensibles, revisarse al menos una vez al año (art. 37). Ante una vulneración, el responsable debe informar a los titulares y a la Agencia en un plazo de cinco días hábiles (arts. 38 y 39) (Poder Ejecutivo de Costa Rica, 2013). El reglamento no incluye un catálogo de controles técnicos; este trabajo usa los controles de ISO/IEC 27001 como referencia para demostrar las medidas. La coherencia con este trabajo es directa: la tabla de riesgos con probabilidad e impacto y la matriz de evaluación con evidencia son la manera en que el DBA demuestra que las medidas existen, están documentadas y se revisan.

ANEXO

Capturas de evidencia

Salidas reales de SQL Developer del 25/10/2026 (script 01, conexión SYSTEM a XEPDB1).

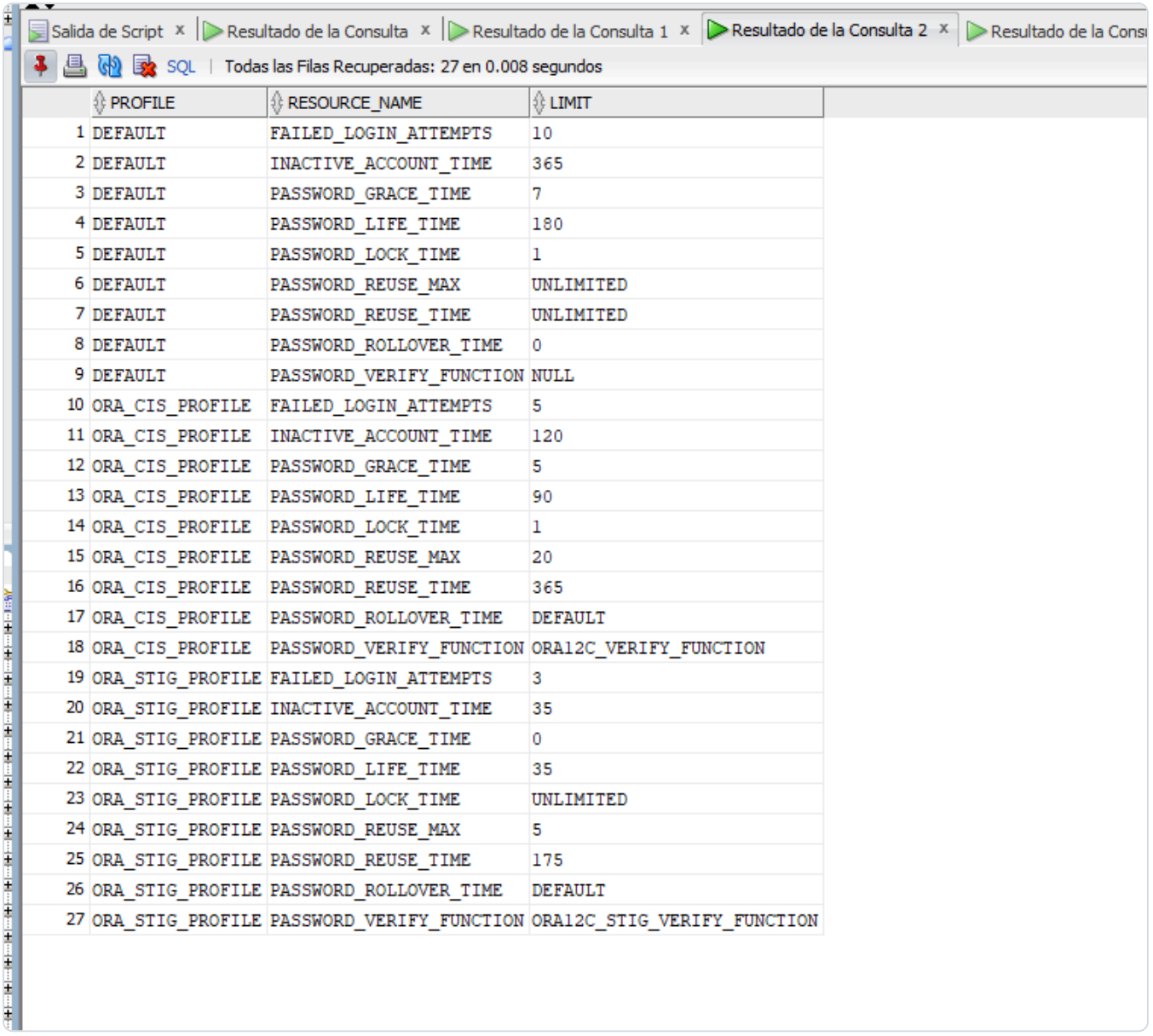


Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1 | Resultado de la Consulta 2 | Resultado...

SQL | Todas las Filas Recuperadas: 2 en 0.002 segundos

	USERNAME	ACCOUNT_STATUS	CREATED	LOCK_DATE	EXPIRY_DATE	LAST_LOGIN	PROFILE	AUTHENTICATION_TYPE
1	PDBADMIN	OPEN	21/08/26	(null)	17/02/27	(null)	DEFAULT	PASSWORD
2	AUDITORIA	OPEN	21/08/26	(null)	17/02/27	24/08/26 00:44:50.000000000 AMERICA/COSTA_RICA	DEFAULT	PASSWORD

P-01 · A5.16 · Usuarios no Oracle: PDBADMIN y AUDITORIA abiertas.



Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1 | Resultado de la Consulta 2 | Resultado de la Consu

SQL | Todas las Filas Recuperadas: 27 en 0.008 segundos

	PROFILE	RESOURCE_NAME	LIMIT
1	DEFAULT	FAILED_LOGIN_ATTEMPTS	10
2	DEFAULT	INACTIVE_ACCOUNT_TIME	365
3	DEFAULT	PASSWORD_GRACE_TIME	7
4	DEFAULT	PASSWORD_LIFE_TIME	180
5	DEFAULT	PASSWORD_LOCK_TIME	1
6	DEFAULT	PASSWORD_REUSE_MAX	UNLIMITED
7	DEFAULT	PASSWORD_REUSE_TIME	UNLIMITED
8	DEFAULT	PASSWORD_ROLLOVER_TIME	0
9	DEFAULT	PASSWORD_VERIFY_FUNCTION	NULL
10	ORA_CIS_PROFILE	FAILED_LOGIN_ATTEMPTS	5
11	ORA_CIS_PROFILE	INACTIVE_ACCOUNT_TIME	120
12	ORA_CIS_PROFILE	PASSWORD_GRACE_TIME	5
13	ORA_CIS_PROFILE	PASSWORD_LIFE_TIME	90
14	ORA_CIS_PROFILE	PASSWORD_LOCK_TIME	1
15	ORA_CIS_PROFILE	PASSWORD_REUSE_MAX	20
16	ORA_CIS_PROFILE	PASSWORD_REUSE_TIME	365
17	ORA_CIS_PROFILE	PASSWORD_ROLLOVER_TIME	DEFAULT
18	ORA_CIS_PROFILE	PASSWORD_VERIFY_FUNCTION	ORA12C_VERIFY_FUNCTION
19	ORA_STIG_PROFILE	FAILED_LOGIN_ATTEMPTS	3
20	ORA_STIG_PROFILE	INACTIVE_ACCOUNT_TIME	35
21	ORA_STIG_PROFILE	PASSWORD_GRACE_TIME	0
22	ORA_STIG_PROFILE	PASSWORD_LIFE_TIME	35
23	ORA_STIG_PROFILE	PASSWORD_LOCK_TIME	UNLIMITED
24	ORA_STIG_PROFILE	PASSWORD_REUSE_MAX	5
25	ORA_STIG_PROFILE	PASSWORD_REUSE_TIME	175
26	ORA_STIG_PROFILE	PASSWORD_ROLLOVER_TIME	DEFAULT
27	ORA_STIG_PROFILE	PASSWORD_VERIFY_FUNCTION	ORA12C_STIG_VERIFY_FUNCTION

P-03 · A5.17 y A8.5 · Perfiles de contraseña: DEFAULT sin función de verificación y con 10 intentos.

```
--   * rman target / ; SHOW ALL;            -> CONFIGURE ENCRYPTION FOR DATABASE
```

Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1 | Resultado de la Consulta 2 | Resultado...

SQL | Todas las Filas Recuperadas: 2 en 0.001 segundos

	GRANTEE	GRANTED_ROLE	ADMIN_OPTION
1	SYS	DBA	YES
2	SYSTEM	DBA	NO

P-05 · A8.2 · Rol DBA: solo SYS (con ADMIN OPTION) y SYSTEM.

```
---
SELECT grantee, granted_role
FROM   dba_role_privs
WHERE  admin_option = 'YES'
AND    grantee IN (SELECT username FROM dba_users WHERE oracle_maintained = 'N')
ORDER  BY grantee, granted_role;
```

Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1

SQL | Todas las Filas Recuperadas: 1 en 0.1 segundos

	GRANTEE	GRANTED_ROLE
1	PDBADMIN	PDB_DBA

P-08 · A5.18 · Delegaciones con ADMIN OPTION en usuarios no Oracle: PDBADMIN con PDB_DBA.

Resultado de la Consulta

SQL | Todas las Filas Recuperadas: 8 en 0.032 segundos

	DATO	RESULTADO
1	politicas VPD	12
2	politicas Redaction	0
3	parches aplicados	0
4	verificador AUDITORIA	11G 12C
5	verificador PDBADMIN	11G 12C
6	red: Windows NT TCP/IP NT Protocol Adapter for 64-bit Windows: Version 21.0.0.0.0 - Production	sesion actual
7	red: Encryption service for 64-bit Windows: Version 21.0.1.0.0 - Production	sesion actual
8	red: Crypto-checksumming service for 64-bit Windows: Version 21.0.1.0.0 - Production	sesion actual

P-09, P-10, P-04, P-16 y P-17 · Resumen: 12 políticas VPD (internas), 0 de Data Redaction, 0 parches, verificadores 11G y 12C, banner de red.

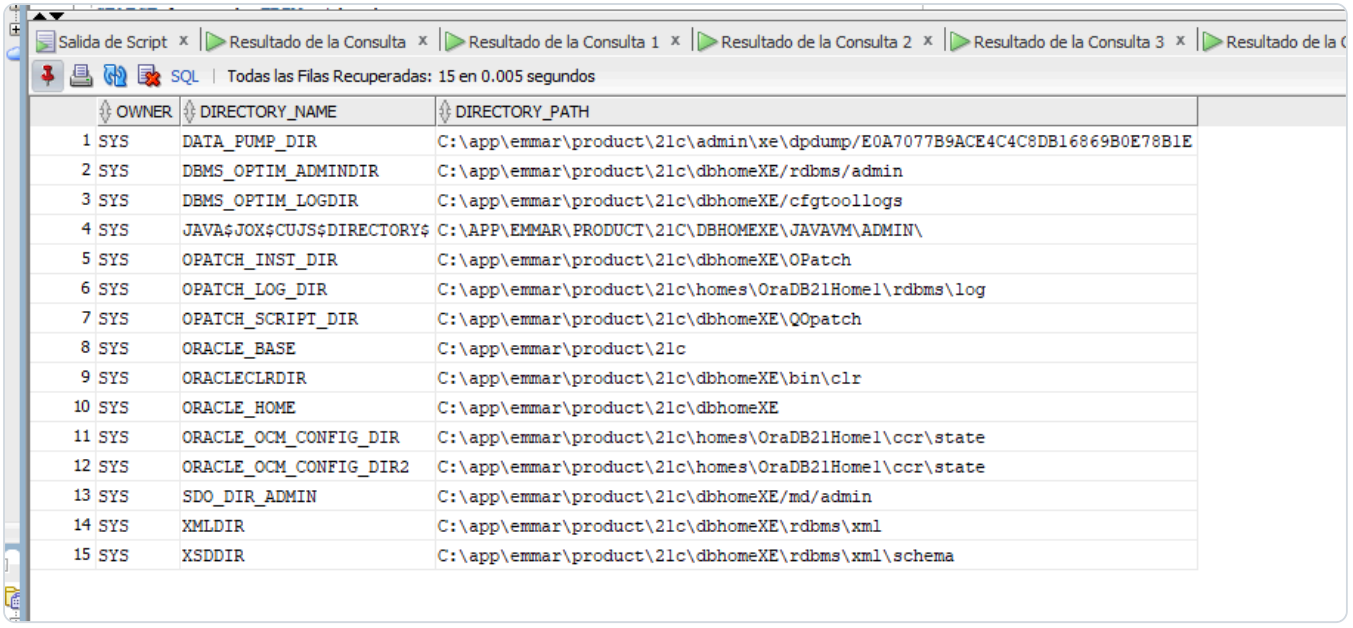
```
AND table_name IN ('UTL_FILE','UTL_HTTP','UTL_TCP','UTL_SMTP','DBMS_DATAPUMP','DBMS_FILE_TRANSFER');
```

Resultado de la Consulta

SQL | Todas las Filas Recuperadas: 9 en 0.385 segundos

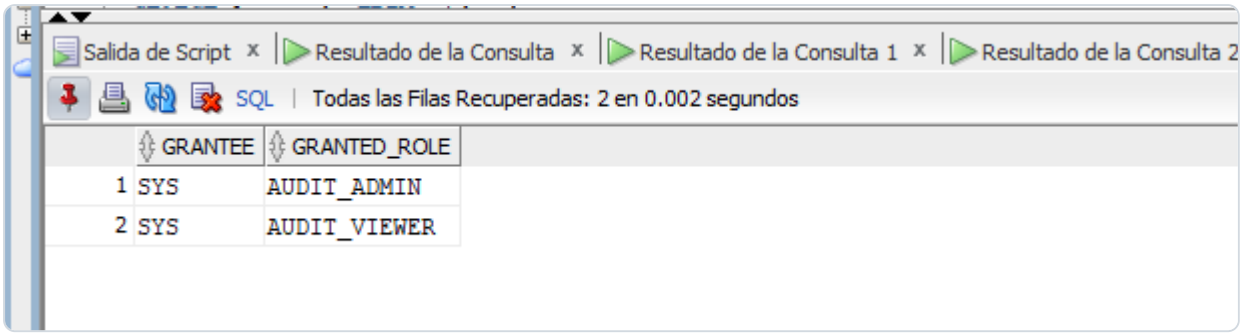
	DATO	RESULTADO
1	audit_trail	DB
2	log_mode	NOARCHIVELOG
3	politica de auditoria activa: ORA_SECURECONFIG	activa
4	politica de auditoria activa: ORA_LOGON_FAILURES	activa
5	EXECUTE a PUBLIC: UTL_TCP	EXECUTE
6	EXECUTE a PUBLIC: UTL_HTTP	EXECUTE
7	EXECUTE a PUBLIC: UTL_FILE	EXECUTE
8	EXECUTE a PUBLIC: UTL_SMTP	EXECUTE
9	EXECUTE a PUBLIC: DBMS_DATAPUMP	EXECUTE

P-12, P-15 y P-11 · A8.15, A8.13 y A8.12 · audit_trail = DB, NOARCHIVELOG, dos políticas de auditoría activas y cinco paquetes ejecutables por PUBLIC.



	OWNER	DIRECTORY_NAME	DIRECTORY_PATH
1	SYS	DATA_PUMP_DIR	C:\app\emmar\product\21c\admin\xe\dpdump/E0A7077B9ACE4C4C8DB16869B0E78B1E
2	SYS	DBMS_OPTIM_ADMINDIR	C:\app\emmar\product\21c\dbhomeXE/rdbms/admin
3	SYS	DBMS_OPTIM_LOGDIR	C:\app\emmar\product\21c\dbhomeXE/cfgtoollogs
4	SYS	JAVAJOXCUJS$DIRECTORY$	C:\APP\EMMAR\PRODUCT\21C\DBHOMEXE\JAVAVM\ADMIN\
5	SYS	OPATCH_INST_DIR	C:\app\emmar\product\21c\dbhomeXE\OPatch
6	SYS	OPATCH_LOG_DIR	C:\app\emmar\product\21c\homes\OraDB21Home1\rdbms\log
7	SYS	OPATCH_SCRIPT_DIR	C:\app\emmar\product\21c\dbhomeXE\QOpatch
8	SYS	ORACLE_BASE	C:\app\emmar\product\21c
9	SYS	ORACLECLRDIR	C:\app\emmar\product\21c\dbhomeXE\bin\clr
10	SYS	ORACLE_HOME	C:\app\emmar\product\21c\dbhomeXE
11	SYS	ORACLE_OCM_CONFIG_DIR	C:\app\emmar\product\21c\homes\OraDB21Home1\ccr\state
12	SYS	ORACLE_OCM_CONFIG_DIR2	C:\app\emmar\product\21c\homes\OraDB21Home1\ccr\state
13	SYS	SDO_DIR_ADMIN	C:\app\emmar\product\21c\dbhomeXE/md/admin
14	SYS	XMLDIR	C:\app\emmar\product\21c\dbhomeXE\rdbms\xml
15	SYS	XSDDIR	C:\app\emmar\product\21c\dbhomeXE\rdbms\xml\schema

P-11b · A8.12 · Directorios: 15, todos de SYS y los que trae Oracle por defecto.



	GRANTEE	GRANTED_ROLE
1	SYS	AUDIT_ADMIN
2	SYS	AUDIT_VIEWER

P-13 · A5.33 · AUDIT_ADMIN y AUDIT_VIEWER solo asignados a SYS.

Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1 | Resultado de la Consulta 2 | Resu

SQL | Todas las Filas Recuperadas: 18 en 0.734 segundos

	GRANTEE	OWNER	TABLE_NAME	PRIVILEGE
1	AUDIT_ADMIN	AUDSYS	DBMS_AUDIT_MGMT	EXECUTE
2	AUDIT_ADMIN	AUDSYS	DV$CONFIGURATION_AUDIT	READ
3	AUDIT_ADMIN	AUDSYS	DV$ENFORCEMENT_AUDIT	READ
4	AUDIT_ADMIN	AUDSYS	CDB_XS_AUDIT_TRAIL	READ
5	AUDIT_ADMIN	AUDSYS	DBA_XS_AUDIT_TRAIL	READ
6	AUDIT_ADMIN	AUDSYS	CDB_UNIFIED_AUDIT_TRAIL	READ
7	AUDIT_ADMIN	AUDSYS	UNIFIED_AUDIT_TRAIL	READ
8	AUDIT_VIEWER	AUDSYS	DBA_XS_AUDIT_TRAIL	READ
9	AUDIT_VIEWER	AUDSYS	DV$CONFIGURATION_AUDIT	READ
10	AUDIT_VIEWER	AUDSYS	CDB_XS_AUDIT_TRAIL	READ
11	AUDIT_VIEWER	AUDSYS	DV$ENFORCEMENT_AUDIT	READ
12	AUDIT_VIEWER	AUDSYS	CDB_UNIFIED_AUDIT_TRAIL	READ
13	AUDIT_VIEWER	AUDSYS	UNIFIED_AUDIT_TRAIL	READ
14	DV_MONITOR	AUDSYS	DV$CONFIGURATION_AUDIT	READ
15	DV_MONITOR	AUDSYS	DV$ENFORCEMENT_AUDIT	READ
16	DV_SECANALYST	AUDSYS	DV$ENFORCEMENT_AUDIT	READ
17	DV_SECANALYST	AUDSYS	DV$CONFIGURATION_AUDIT	READ
18	EXECUTE_CATALOG_ROLE	AUDSYS	DBMS_AUDIT_MGMT	EXECUTE

P-13 · A5.33 · Privilegios sobre AUDSYS: solo roles de Oracle.

Resultado de la Consulta | Resultado de la Consulta 1 | Resultado de la Consulta 2 | Resultado de la Consulta 3 | Resultado de la Consulta 4

SQL | Todas las Filas Recuperadas: 1 en 0.068 segundos

	WRL_TYPE	WRL_PARAMETER	STATUS	WALLET_TYPE	WALLET_ORDER	KEYSTORE_MODE	FULLY_BACKED_UP	CON_ID
1	FILE	(null)	NOT_AVAILABLE	UNKNOWN	SINGLE	UNITED	UNDEFINED	3

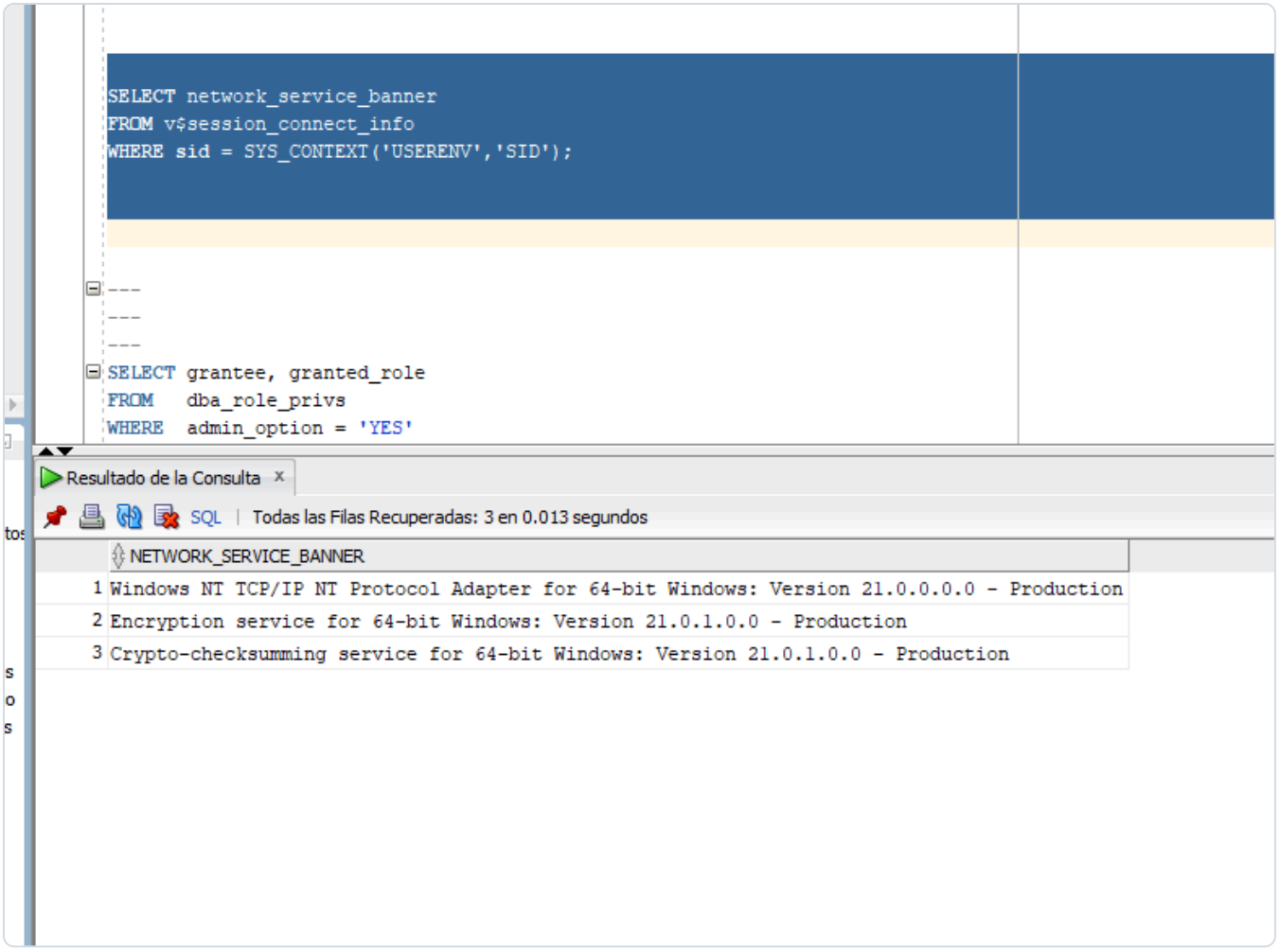
P-14 · A8.24 · Wallet de TDE en NOT_AVAILABLE.

Salida de Script | Resultado de la Consulta | Resultado de la Consulta 1 | Resultadc

SQL | Todas las Filas Recuperadas: 0 en 0.002 segundos

SESSION_...	INPUT_TYPE	STATUS	START_TI...	END_TIME

P-15 · A8.13 · Trabajos RMAN visibles desde el PDB: 0 filas.



P-17 · A8.20 · Banner de red de la sesión: servicios de cifrado cargados, sin algoritmo.

```
C:\> lsnrctl status
  (DESCRIPTION=(ADDRESS=(PROTOCOL=tcp)(HOST=Emmanuel)(PORT=1521)))
  (DESCRIPTION=(ADDRESS=(PROTOCOL=ipc)(PIPENAME=\\.\pipe\EXTPROC1521ipc)))
  (DESCRIPTION=(ADDRESS=(PROTOCOL=tcps)(HOST=Emmanuel)(PORT=5500))(Security=
(my_wallet_directory=C:\APP\EMMAR\PRODUCT\21C\admin\XE\xdb_wallet))(Presentation=HTTP)
(Session=RAW))

C:\> type ...\homes\OraDB21Home1\network\admin\sqlnet.ora
SQLNET.AUTHENTICATION_SERVICES= (NTS)
NAMES.DIRECTORY_PATH= (TNSNAMES, EZCONNECT)

C:\> type ...\homes\OraDB21Home1\network\admin\listener.ora
LISTENER = (DESCRIPTION_LIST = (DESCRIPTION =
  (ADDRESS = (PROTOCOL = TCP)(HOST = Emmanuel)(PORT = 1521))
  (ADDRESS = (PROTOCOL = IPC)(KEY = EXTPROC1521)) ))
```

M-01 · A8.20 · Salida de consola pegada por el estudiante (extracto): SQL por TCP en claro en el 1521; TCPS solo en el 5500 (XDB); sin parámetros de cifrado en sqlnet.ora.

FASE ACTUAR

Correcciones aplicadas

- **A-01** · `ALTER USER PDBADMIN ACCOUNT LOCK`: la cuenta pasó de OPEN a LOCKED. A5.16 sube de 2 a 3.

- **A-02** · El perfil `ORA_CIS_PROFILE` rechaza una clave corta con ORA-28003 al crear `USR_PRUEBA_ISO`.
- **A-03** · `REVOKE EXECUTE … FROM PUBLIC` falló con ORA-01927 desde SYSTEM, porque el otorgante es SYS. Queda como hallazgo abierto.
- **A-04** · La política `POL_ISO_ADMIN_USUARIOS` está activa y registra CREATE USER y GRANT (código 0) y los intentos fallidos. A8.15 sube de 2 a 3.

Tres de cuatro correcciones aplicadas. Antes de actuar cumplían 3 controles; después, 5 (A5.16 y A8.15 pasaron a «Cumple»).

ALCANCE

Límites de esta evaluación

- **Alcance:** la evaluación se hizo sobre una instancia local de Oracle 21c XE, instalada en el equipo del estudiante con la configuración por defecto. Los resultados «No cumple» describen esa instalación de pruebas, no una base de datos de producción de una organización.
- Unified Auditing en modo puro no está disponible en XE. Se usó el modo mixto, donde las políticas de auditoría unificada sí funcionan, y quedó demostrado con la prueba A-04.
- Database Vault y Label Security no están disponibles en XE; ninguno es necesario para los controles evaluados.
- TDE, Data Redaction y VPD sí están disponibles, pero al inicio no había nada configurado con ellos.
- No se revisó la configuración de RMAN desde consola; las filas que dependen de eso quedan sin evidencia. Los archivos `sqlnet.ora` y `listener.ora` sí se revisaron (M-01).
- Se evaluó un solo PDB (`XEPDB1`) y no hay clones DEV/TEST en esta instancia para revisar.
- La corrección A-03 no se aplicó: el privilegio lo otorgó `SYS` y la sesión era `SYSTEM`.

Referencias (APA 7)

AMIS Technology Blog. (s. f.). *Unified Auditing not possible for Oracle Database XE (Express Edition)*. https://technology.amis.nl/database/unified-auditing-not-possible-for-oracle-database-xe-express-edition/

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley n.º 8968: Protección de la persona frente al tratamiento de sus datos personales*. Ministerio de Ciencia, Innovación, Tecnología y Telecomunicaciones. https://www.micitt.go.cr/sites/default/files/marco_juridico_legal/08.%20Ley%20n.%C2%B0%208968%20Ley%20de%20Protecci%C3%B3n%20de%20la%20Persona%20frente%20al%20tratamiento%20de%20sus%20datos%20personales..pdf

International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (3.ª ed.). https://webstore.iec.ch/publication/79694

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security controls* (ISO/IEC 27002:2022).

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf

Oracle. (s. f.-a). Backing up to Oracle Database Backup Cloud Service using dual-mode encryption. En *Using Oracle Database Backup Cloud Service*. https://docs.oracle.com/en/cloud/paas/db-backup-cloud/csdbb/backing-oracle-database-backup-cloud-service-using-dual-mode-encryption.html

Oracle. (s. f.-b). Configuring Transport Layer Security authentication. En *Oracle Database Security Guide*. https://docs.oracle.com/en/database/oracle/oracle-database/19/dbseg/configuring-secure-sockets-layer-authentication.html

Oracle. (s. f.-c). *Database licensing information user manual, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/dblic/Licensing-Information.html

Oracle. (s. f.-d). Introduction to Oracle Advanced Security. En *Oracle Database Advanced Security Guide* (Release 19). https://docs.oracle.com/en/database/oracle/oracle-database/19/asoag/introduction-to-oracle-advanced-security.html

Oracle. (s. f.-e). *Oracle Database Express Edition — Licensing restrictions, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/xeinl/licensing-restrictions.html

Oracle. (s. f.-f). Restricting access with Oracle Virtual Private Database. En *Oracle Database 2 Day + Security Guide* (Release 12.2). https://docs.oracle.com/en/database/oracle/oracle-database/12.2/tdpsg/restricting-access-with-oracle-virtual-private-database.html

Poder Ejecutivo de Costa Rica. (2013). *Decreto Ejecutivo n.º 37554-JP: Reglamento a la Ley de protección de la persona frente al tratamiento de sus datos personales* (Alcance Digital n.º 42 a La Gaceta n.º 45, 5 de marzo de 2013). Tribunal Supremo de Elecciones. https://www.tse.go.cr/pdf/normativa/reglamentoleyproteccionpersona.pdf

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

SGS. (2022, julio). *Key changes in ISO/IEC 27002:2022*. https://www.sgs.com/en-uz/news/2022/07/key-changes-in-iso-iec-27002-2022

Escuela de Informática, Universidad Nacional de Costa Rica · II Ciclo 2026 · Los scripts `01_verificacion_confidencialidad.sql` y `02_actuar_correcciones.sql` acompañan este informe.